Monthly Intelligence Dispatch

November 2020

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB released **Hi-Tech Crime Trends 2020/2021**, the company's latest analytical report about global cybercrime trends and forecasts.
- As many as three APT groups have attacked at least seven companies involved in researching vaccines and treatments for COVID-19 in recent months.
- Group-IB linked the shutdown of a power unit at the Kudankulam Nuclear Power Plant in 2019 to a successful attack against NPCIL (the Nuclear Power Corporation of India Limited).
- A new hacker group was discovered. The group, which is called CostaRico, targets the financial sector. This is the fifth mercenary hacker group security experts have detected this year.
- Group-IB discovered a new fraud scheme involving the brand of the popular streaming platform Twitch.
- The Chilean company **Cencosud**, one of the largest retailers in South America, fell victim to an Egregor ransomware attack.
- New ransomware called Pay2Key and used in targeted attacks was discovered.
- Group-IB warns about an increase in domain hijacking cases. At least **30,500** domains of popular hosting services are at risk internationally.
- A new banking Trojan called Ghimob was discovered. The malware targets Android users.
- Group-IB and Europol prevented approximately €40 million in losses for banks.
- INTERPOL announced the end of a successful joint operation led together with Group-IB and the Nigerian police, in which a criminal group that had compromised about 500,000 government and private sector companies in 150 countries was taken down.

Hi-Tech Crime Trends

The highlight of November 2020 was Group-IB's global conference **CyberCrimeCon2020**, where the **Hi-Tech Crime Trends 2020/2021** report was presented. The report focuses on cybercrime trends and threats to various sectors, such as finance, telecommunications, retail, production, and energy. You can download it here.

Ransomware caused the most disruption and financial damage (over $1 billion). Evidently, security tools used by companies miss ransomware and are not able to detect and block such threats at an early stage. The main targets of ransomware were the United States, the United Kingdom, Canada, France, and Germany. These countries suffered 381 attacks out of 505, i.e. 75%. Since 2019, Maze and Revil have been the most harmful programs accounting for over 50% of all successful attacks.

Over the past year, seven new APT groups have been identified. Group-IB has also identified six known threat groups that remained unnoticed for several years. Nuclear power has become an obvious target for attackers. No such attacks were reported in the previous year. This year, however, Iran's nuclear energy facilities were sabotaged, while facilities in India were subject to espionage attacks. Threat actors are particularly interested in India because the country is developing nuclear technology and thorium-based reactors.

For the world's economies, the turbulent times of COVID-19 have resulted in the rise of the market for selling access to corporate networks, where the goal is to gain access to corporate networks for ransomware attacks. Between H2 2019 and H1 2020, the number of access-for-sale offers increased 2.6-fold (from 138 to 362) compared to the previous period.

In 2020, there have so far been no public reports on thefts through SWIFT, ATM Switch, payment gateways, or ATMs when they were accessed through a bank's network. The cybercriminal groups Cobalt and Silence, which previously focused on targeted attacks on banks to steal and withdraw money, have switched to using ransomware and presumably joined ransomware affiliate programs.

Stronium

Zinc

Cerium

Microsoft says that as many as three APT groups have attacked at least seven companies involved in researching vaccines and treatments for COVID-19 in recent months. The Russian-speaking threat group Strontium (aka Fancy Bear, APT28, etc.) and the North Korean groups Zinc (Lazarus) and Cerium are said to be behind the attack. Microsoft's article says that the attacks have targeted vaccine makers that have COVID-19 vaccines in various stages of clinical trials. One is a clinical research organization involved in trials, and one has developed a COVID-19 test. The victim companies, whose names have not been disclosed, are based in Canada, France, India, South Korea, and the US.

According to Microsoft, Strontium used password-spray and brute-force login attempts to steal login credentials, break into people's accounts, and steal confidential information. Password spraying involves attempting to log in with multiple usernames using one commonly used password in an effort to identify poorly protected accounts.

Zinc (aka Lazarus) has primarily used spear-phishing, sending messages with fabricated job descriptions pretending to be recruiters. The second North Korean group Cerium seems to be a new player. Microsoft says that this group engaged in spear-phishing email lures using COVID-19 themes while masquerading as World Health Organization representatives.

NPCIL

Group-IB linked the shutdown of a power unit at the Kudankulam Nuclear Power Plant to a successful attack against NPCIL (the Nuclear Power Corporation of India Limited). In September 2019, Group-IB specialists discovered an archive that contained Dtrack, a remote administration tool attributed to the North Korean group Lazarus. There were logs that contained data from the compromised computer of an NPCIL employee. All files in the archive were compiled at different times, but the main file was dated January 30, 2019, i.e., about six months before the detection. This suggests that the hackers remained unnoticed in the victim's network for a long time.

It was later discovered that the **Kudankulam Nuclear Power Plant**, which is situated in the south of the state of Tamil Nadu, was compromised as a result of a cyberattack. On October 19, 2019, the power plant's second power unit was shut down. Group-IB Threat Intelligence & Attribution analysts believe that the two events (the successful attack against NPCIL and the incident at Kudankulam) may be linked. According to official announcements, the power unit was shut down because of an SG level low (levels of steam being too low to turn the turbine).

After researcher **Pukhraj Singh** tweeted that a cyberattack had occurred, the power plant's management denied it. However, NPCIL later admitted that a cyberattack had indeed taken place: a Trojan penetrated the power plant's administrative network infecting one computer but did not reach the critical internal network used for nuclear reactor management.

Interestingly, even isolating networks is not a cure-all: attackers add new tools that involve USB drives to overcome air gaps. As traditional security tools are not always capable of protecting against the abovementioned threats, it is worth considering Group-IB Threat Hunting Framework and Group-IB Threat Intelligence & Attribution — breakthrough solutions for analyzing threats and hunting threat actors.

Domain hijacking

Group-IB warns about an increase in domain hijacking cases. At least **30,500** domains of popular hosting services are at risk internationally. Threat actors mostly use hijacked resources to conduct phishing attacks, commit financial fraud, mail out malware, or infect visitors of compromised websites. This threat was reported by CERT-GIB in a meeting with the Coordination Center for TLD .RU/.РФ. CERT-GIB also notified Russian and international hosting services and regional Internet registries about the situation. This fall, in their monitoring of phishing websites targeting the customers of a major Russian bank Group-IB analysts noticed that threat actors used legitimate .RU, .SU, and .РФ domains that belonged to regular users and companies, rather than compromised or newly created resources. Group-IB has established how the hijacking is organized. The owners of domain names that are not linked to hosting accounts (even though purchased and not blocked by registrars) fall victim. There are two scenarios when this can happen: a domain is neglected or it has been purchased very recently. Threat actors monitor such domains and publish their own content on the servers of hosting services using other people's domains. The entire hijacking process takes from 30 minutes to several hours. Once threat actors hijack a domain, they can post their content, create email accounts, and use the resource to commit financial fraud (steal money and bank card data including CVV and CVC), send out emails with malicious attachments, and infect visitors with banking Trojans, spyware, and ransomware (watering hole attacks).

CostaRico

BlackBerry reported about the discovery of a hacker group called CostaRicto. This is the fifth mercenary hacker group the experts have detected this year. As early as spring, specialists at Google Threat Analysis Group warned that the number of such groups would increase and earlier this year security specialists reported about mercenary hacker groups BellTrox (aka Dark Basin), DeathStalker (aka Deceptikons), Bahamut, and an unnamed hacker group.

Threat actors launched attacks across the globe, including Europe, the US, Asia, Australia, and Africa. BlackBerry says that most victims of CostaRicto appear to be located in South Asia (especially India, Bangladesh and Singapore). The experts conclude that the threat actors could be based in that region. While the victims' profiles are diverse, a large number of them are financial institutions.

CostaRicto mostly uses specially developed and previously unknown malware; however, the group does not use any innovative methods in their attacks. For example, most of their attacks involve stolen credentials or traditional spear-phishing emails, which usually contain a Trojan tracked by BlackBerry as Sombra or SombRAT. The Trojan gives CostaRicto operators access to infected hosts and helps find confidential files and steal important documents. Stolen data is usually sent to the hackers' command and control (C&C) server, which is hosted on a darknet and can only be accessed through Tor. In addition, infected hosts usually connect to the threat actors' C&C servers through several proxies and SSH tunnels so that the malicious traffic is concealed.

Twitch

Group-IB discovered a new fraud scheme involving the popular streaming platform Twitch. Threat actors copy streams of famous gamers and add banners promising easy money. The banners redirect users to fraudulent resources, where they have their money and bank card data stolen. Group-IB has warned Twitch about the threat. The idea behind the new fraud scheme is as follows. Threat actors find channels of popular streamers and create clone accounts with similar names and design where they show recorded original streams with inserted banners advertising easy money, which usually involves prizes. Threat actors also publish a special command (!inst) in stream chats and users who click on a banner are redirected to a fraudulent resource, e.g., //winstainq.dub/draw. What follows next is a common technique: the victim is offered a sum of up to $5,000 in exchange for a small arrangement and transfer fee. The user enters their bank card data on the fraudulent resource and as a result has a small sum and their card data stolen.

T Plus

Fraudsters sent over 100 emails with fabricated invitations to bid posing as the energy company T Plus. Among the tenders were cleaning services, a workwear production project for $77,000, and production of t-shirts featuring the company's logo for $30,700. The emails stipulated that a $400 certificate had to be purchased, after which the author of the mailout promised to sign an agreement in one week. Schemes involving tenders are a well-known fraud method which is found in many areas, such as oil, metallurgy, and agriculture. Fraudsters are often well prepared: they create clone website, fake email accounts, and document templates in advance; they are well-aware of market prices and speak the same language with tender participants. Damage from this type of fraud can amount to hundreds of thousands or even millions of dollars. Over the past three years, this kind of fraud has been quite frequent, which indicates that it might be a stable way for threat actors to make money.

Egregor

The Chilean company **Cencosud**, one of the largest retailers in South America, fell victim to an attack involving the Egregor ransomware, which started being active only recently in early September, soon after the Maze operators announced that they were shutting down their activity. Security specialists say that Maze, Egregor, and Sekhmet are essentially the same program, with the same people behind them. Over the course of just two months, Egregor attacked major game developers Ubisoft and Crytek as well as the largest network of bookstores in the United States Barnes & Noble. The Cencosud incident took place in mid-November and had a significant impact on the company's operations: the malware encrypted devices in almost all Cencosud stores. The Argentinian newspaper Clarín writes that retail stores are still operating, but with restrictions. Many printers in stores in Chile and Argentina began to print ransom notes. This is a well-known feature of Egregor: after finishing encryption, the malware automatically prints ransomware messages on any available printers. If a large company's network was attacked, it could result in thousands of such flyers being printed. The extortionists write that they stole the company's data and threaten to disclose it if they do not receive a ransom.

Pay2Key

New ransomware used in targeted attacks was discovered. Pay2Key infiltrates organizations' networks through poorly protected RDP connections. Attacks in Israel and Brazil have so far been detected. According to **Check Point Software Technologies,** the new ransomware emerged on the Internet in late October. The company's research revealed that the Pay2Key operators usually attacked organizations at night and could rapidly spread the ransomware across entire internal networks in an hour. The threat actors demand that a ransom be paid within a specified period, otherwise the price will increase two-fold. They usually demand a ransom of up to nine Bitcoin (up to $139,000 with the current rate). To ensure that a paid key works, the victim is asked to email four test files encrypted with Pay2Key. The threat actors' message says that important information has been extracted from the victim's network and that it will be published if the demanded ransom is not paid. Experts have not yet checked this statement. The new ransomware is poorly detected by VirusTotal antiviruses and is being actively developed.

Mattel

The American toy manufacturer Mattel reported a cyberattack by unknown ransomware, which affected certain business operations. Mattel assured that they had recovered from the incident without significant financial losses. The incident came to light after the company published their quarterly report (form 10-Q), which was sent to the United States Securities and Exchange Commission. The document says that the attack took place in July 2020 and was successful at first, with a number of systems being encrypted. Mattel responded to the incident and "contained the attack . . . although some business functions were temporarily impacted."

Ragnar Locker

On November 1, 2020, the Italian beverage manufacturer **Gruppo Campari**, which owns brands such as Campari, Cinzano, SKYY vodka, Epsolon, Wild Turkey, Grand Marnier, and Appleton, fell victim to a Ragnar Locker ransomware attack. The hackers write that they stole about 2 TB of information from the company. They have already posted screenshots of the stolen data on their website and are demanding about $15 million in ransom for restoring the information and removing the stolen data. The next day the Japanese corporation **Capcom** suffered a hacker attack: the breach affected the video game developer's business operations, including the email system. According to official information, unknown threat actors launched an attack in the morning of November 2, 2020, which affected some of the Capcom Group networks disrupting a number of systems. For instance, the email system and file servers were impacted, but the incident did not affect access to the company's online games or websites. It appears that parts of the corporate network were shut down by Capcom employees to prevent further spread of the unnamed threat. Bleeping Computer writes (citing the security researcher Pancak3 who discovered a sample of the malware) that the company was attacked by the Ragnar Locker ransomware. By running this ransomware version the experts were able to get access to the ransom note, in which the hackers state that they have stolen 1 TB of unencrypted files from the corporate networks in Japan, the USA, and Canada.

Ghimob

A new banking Trojan called Ghimob was discovered. The malware targets Android users and was developed by the threat group Guildma. Once the Trojan infects a system, its operators gain remote access to the victim's device and can carry out fraudulent transactions. Mobile banking apps, fintech companies, exchanges, and cryptocurrencies are the main targets of this Trojan. The threat actors use phishing emails with a link that downloads an APK installer to victim Android devices. After installation, the Trojan hides its icon and abuses Android's accessibility features to allow the Trojan to capture data, manipulate screen content, and provide full remote control to the threat actors. When the attackers want to carry out a transaction, they can display a black screen as an overlay while the victim's banking app is launched in the background. Ghimob targets a total of 153 apps.

Platupus

Researchers at the Graz University of Technology and the University of Birmingham published a research study in which they described an attack called Platypus in detail (Power Leakage Attacks: Targeting Your Protected User Secrets). A Platypus attack relies on having access to Intel's Running Average Power Limit (RAPL), a feature designed for monitoring and controlling the CPU and DRAM power consumption. RAPL has been used to monitor and debug software and hardware performance. The experts say that this vector can be used to infer processor data. By launching a Platypus attack, the specialists demonstrated that they could observe variations in power consumption to distinguish different instructions and different Hamming weights of operands and memory loads, allowing inference of data loaded in the CPU.

Arrests and sentences

Falcon

On November 25, 2020, **Craig Jones**, Cybercrime Director at **INTERPOL** announced at **CyberCrimeCon'20** the end of a successful joint operation led together with Group-IB and the Nigerian police, in which a criminal group that had compromised about 500,000 government and private sector companies in 150 countries was taken down. Experts at Group-IB's computer emergency response team CERT-GIB and high-tech crime investigation department for APAC established the identities of the cybercriminals by using an innovative system for analyzing cyberthreats and hunting threat actors. The Nigerian group was tracked for about a year, over which separate events, attacks, and tools of the attackers were linked. As a result, three individuals were arrested in Lagos, Nigeria.

Carding Action 2020

Group-IB and Europol prevented about €40 million in losses for banks. Tobias Wieloch of the European Cybercrime Centre (EC3), talked about Carding Action 2020, an operation against the sale of compromised bank card data. In addition to Europol, the three-month operation was led by law enforcement agencies from Italy, Hungary, and the UK (in particular, the Dedicated Card and Payment Crime Unit of the of the London Metropolitan and the City of London Police). Group-IB, the only private-sector cybersecurity company involved in the operation, provided information on approximately 90,000 pieces of payment data compromised through phishing websites, banking Trojans for PC and Android, and JS sniffers, which threat actors inject into online stores' websites to capture data entered by users, such as payment card numbers, names, addresses, and passwords. The large number of individual pieces of information was gleaned from non-public sources (card shops, underground forums, botnets, and JS sniffers) and analyzed by Group-IB Threat Intelligence & Attribution, a system for analyzing threats and hunting threat actors. To prevent illegal use of stolen data, Europol coordinated information exchange between law enforcement agencies, banks, and payment systems in real time. According to Europol, operation Carding Action 2020 helped prevent about €40 million in losses for financial organizations.

Arrests and sentences

Aleksandr Brovko

The United States Department of Justice announced that Aleksandr Brovko was sentenced to eight years in prison. In 2019, Brovko was arrested in the Czech Republic, from where he was extradited to the United States following a probe into the activities of Russian hacking groups. Brovko worked with Alexander Tverdokhlebov, who emigrated from Russia in 2007, gained US citizenship, and lived in California. In 2017, Tverdokhlebov was arrested and sent to prison for nine years for running a botnet of about 500,00 infected computers. Brovko's indictment in 2018 mentions Tverdokhlebov as "A.T." Tverdokhlebov would obtain access to thousands of hacked PCs, all remote-controlled by malware that also harvested people's usernames and passwords from those computers. Brovko was tasked with sifting through the logs of these botnets for Internet banking credentials, which were subsequently used by fellow conspirators to steal millions of dollars from Americans' accounts in fraudulent transfers. He pleaded guilty in the US in February to conspiracy to commit wire fraud and bank fraud. Brovko was sentenced to eight years in jail and a further five years of supervised release.

Volodymyr Kvashuk

Volodymyr Kvashuk, a former Microsoft software engineer who had been charged with stealing over $10 million, was sentenced to nine years in prison. Law enforcement agencies identified the criminal about two and a half years ago. Prosecutors established that Kvashuk was guilty on five counts of wire fraud and six counts of money laundering as well as identity theft and other offences. Kvashuk worked first as a contractor at Microsoft and then as an employee from August 2016 until he was fired in June 2018 when information about his offences came to light. It was also established that Kvashuk made use of his access rights to steal digital gift cards, which he later sold online. He used three test email accounts associated with other employees in an attempt to cover his tracks. These accounts, combined, purchased roughly $10.1 million worth of currency stored value.

Forecasts and warnings

- Next year, there will probably be no traditional attacks on banks for theft purposes. There may be rare incidents, but this type of activity will no longer be as widespread as it used to be. As with other sectors, ransomware operators will pose the biggest threat to the financial vertical. This hypothesis is confirmed by the increasing number of offers selling access to corporate networks belonging to financial institutions*.
- Another reason why the number of ransomware attacks is increasing is the fact that companies' cybersecurity tools are not able to detect and block them.
- Stealing information about financial transactions of VIP clients and publishing it online may become a more serious threat than data encryption. Such attacks may cause significant financial damage and make banks pay ransoms to threat actors more readily.
- The COVID-19 pandemic has forced a significant number of people to work from home, and many of them will become permanent work-from-home employees after the pandemic ends. As such, the number of attacks on home routers and storage systems will continue to increase given that they help advanced crime groups and state-sponsored actors access corporate data without infiltrating an organization's perimeter.
- Data stolen by various hacker groups may be used by threat actors to gain access to email accounts or cryptocurrency wallets, commit financial fraud, or engage in espionage; such data can also be sold on hacker forums.
- To conduct attacks more effectively, threat actors will target not only large energy companies but also last-mile energy distributors and small suppliers that offer additional services to energy corporations.
- The lack of strong communication channels between organizations that fight cybercrime coupled with the challenging political situation in the world results in the appearance of new threat groups who feel that they are safe. Another factor that helps cybercriminals make money by demanding ransoms is the fact that businesses underestimate this threat and lack proactive security tools.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com